POL- AI Policy

MERGE TechOps Policy

Document Control

Document Number:	POL-0011
Version:	2.0
Author:	Roze San Nicolas
Last Updated:	Feb 18, 2026
Document Type:	Policy
Related Procedure:	🗋 File

---

1. Purpose

This document defines the policy for Artificial Intelligence (AI) systems security within MERGE TechOps. This policy is intended for all employees, security personnel, technology administrators, and AI system operators. This policy establishes the governance framework for MERGE's secure and ethical use of AI systems, ensuring comprehensive AI threat management, data protection, model security, and compliance through alignment with HITRUST CSF v11.5 r2 AI Security Assessment (ai2) requirements, NIST AI RMF v1.0, ISO/IEC 42001:2023, OWASP Top 10 for LLMs, and the MITRE ATLAS framework.

This policy serves as the enterprise-level AI governance document. Vertical-specific teams – AI Garage, DevSecOps, and TechOps (Information Security, Security Operations, System Operations) – shall establish and maintain tool-specific procedures implementing these requirements.

2. Scope

This policy applies to all MERGE full-time and part-time employees, MERGE interns, MERGE contract workers, and all providers when rendering services as a

Business Associate. Persons under contract providing work-related services to MERGE must adhere to these policies, but will have limited access to company systems, with access only to AI tools and data directly related to their current contracted work.

- Applies To: All MERGE verticals, AI Garage, DevSecOps, TechOps (SysOps/InfoSec/SecOps), managers overseeing AI system users, third-party vendors providing AI-enabled services
- Systems Involved: MERGE AIgency platform and associated AI services, agency-approved generative AI tools (Claude, Gemini, Jasper, Lovable), client-facing AI integrations, AI development/testing/production environments on GCP, AI model APIs and inference endpoints, data pipelines for AI training and inference, Google SecOps SIEM (AI system monitoring), SentinelOne EDR, Vanta GRC
- Exclusions: Personal use of public AI tools on personal devices outside MERGE work; AI systems operated entirely by third-party SaaS with no MERGE data processed; sandboxed research evaluations with no production data (governed by AI Garage evaluation procedures)

3. Roles and Responsibilities

3.1. Information Security

The Information Security team maintains ultimate accountability for AI security governance, compliance, and risk management.

1. Define and maintain AI security policies, standards, and risk assessment frameworks
2. Maintain the AI Systems Inventory, document all AI systems in scope, risk classification, data flows, and responsible owners
3. Conduct or coordinate AI-specific risk assessments quarterly and upon material system changes
4. Verify compliance through audits, Vanta GRC monitoring, SIEM analysis, and HITRUST validated assessment
5. Coordinate with auditor for AI security control assessment activities

3.2. TechOps & SecOps:

TechOps & SecOps are responsible for continuous monitoring, threat detection, and incident response for AI systems.

1. Monitor AI systems for anomalous behavior, unauthorized access, and security events through Google SecOps SIEM and SentinelOne EDR

2. Maintain AI-specific incident response procedures
3. Execute AI system access reviews and enforce access control policies
4. Maintain audit logging and evidence collection for AI system

3.3. AI Garage:

The AI Garage is responsible for AI development, model management, and platform operations.

1. Complete annual AI Engineering security awareness training
2. Establish and maintain tool-specific procedures for AI model development, testing, deployment, and life cycle management
3. Maintain AI system architecture documentation, model inventories, and training data provenance records
4. Implement model versioning, change control, pre-deployment testing, and bias assessment programs
5. Enforce guardrails, output filtering, and metaprompt security for LLM-based systems.

3.4. DevSecOps:

DevSecOps is responsible for integrating security into the AI development life cycle.

1. Establish and maintain procedures for secure AI development, pipeline security, and automated security testing
2. Enforce separation of development, testing, and production environments for AI systems
3. Implement automated security scanning in CI/CD pipelines for AI model deployments
4. Maintain API security controls, including authentication, authorization, and rate limiting for AI interfaces

3.5. Managers:

Managers ensure their teams comply with AI security policies and report incidents.

1. Ensure team members complete AI security awareness training before AI system access
2. Review and approve AI tool access requests with documented business justification
3. Identify and escalate unauthorized AI tool adoption or policy violations

3.6. All Employees & Vertical Leads:

1. Complete annual security awareness training and acknowledge AI policy with the employee handbook.
2. Safeguard credentials for AI systems; do not share API keys, tokens, or access credentials.
3. Do not input PII, PHI, or client confidential data into any AI system unless authorized under change management protocols.
4. Report suspected AI security incidents within 24 hours to Information Security.

4. Definitions

4.1. Key Words

1. **AI System:** An engineered or machine-based system that generates outputs such as predictions, recommendations, decisions, or content that can influence physical or virtual environments.
2. **Generative AI:** AI systems capable of generating text, images, audio, video, code, or other content based on learned patterns from training data..
3. **Large Language Model (LLM):** A type of AI model trained on large datasets of text that can generate, summarize, translate, and analyze natural language.
4. **Prompt Injection:** An attack where malicious inputs manipulate an AI model's behavior, bypass safety controls, or extract sensitive information.
5. **Data Poisoning:** An attack where training data is intentionally corrupted to cause incorrect model behavior.
6. **Model Evasion:** An attack where inputs are crafted to cause an AI model to misclassify or produce incorrect outputs.
7. **Model Extraction:** An attack aimed at recreating or stealing a proprietary AI model by systematically querying.
8. **Hallucination:** An AI output that is factually incorrect or fabricated, presented with apparent confidence.
9. **Metaprompt:** System-level instructions that define an AI model's behavior, safety boundaries, and operational parameters.

10. **PII:** Personally Identifiable Information – information directly or indirectly related to an identifiable individual.

11. **PHI:** Protected Health Information – individually identifiable health information as defined under HIPAA.

5. Policy Overview

The following policy statements establish mandatory requirements for MERGE AI systems security, aligned with HITRUST CSF v11.5 r2 ai2 control domains.

5.1. AI System Governance

MERGE shall maintain a formal AI governance program, ensuring all AI systems are inventoried, risk-assessed, and managed throughout their life-cycle.

1. All AI systems must be registered in TechOps and Procurement Systems Inventory with documented purpose, data flows, model type, risk classification, and responsible owner.
2. This policy shall be reviewed at least annually, approved by TechOps leadership, and communicated to all affected personnel.
3. AI-specific procedures shall be established by each responsible vertical (AI Garage, DevSecOps, TechOps) and reviewed at least annually.
4. The Change Management Board approves new AI deployments and significant model changes prior to production.

5.2. AI Risk Management

MERGE shall implement AI-specific risk assessments addressing threats identified in the MITRE ATLAS framework and OWASP Top 10 for LLMs.

1. AI risk assessments shall be conducted quarterly, upon material system changes, and when new AI systems are introduced.
2. Assessments shall address data poisoning, model evasion, prompt injection, model extraction, hallucination risks, and AI supply chain compromise.
3. Third-party AI services shall be assessed for security risk prior to adoption and regularly, per Third-Party Risk Management protocols with the procurement team.
4. AI systems processing PII, PHI, or client confidential data must undergo a data protection impact assessment prior to deployment.

5.3. AI Data Privacy and Protection

MERGE shall ensure that the data used in AI systems meets applicable privacy regulations, contractual obligations, and the principle of data minimization.

1. Employees shall not input PII, PHI, or client confidential data into any AI system unless: (a) explicitly authorized in an approved SOW or project charter; (b) reviewed and approved by the Change Management Board and Data Privacy/Data Protection Officer; (c) appropriate technical safeguards are documented and in place; and (d) the AI provider's data processing terms permit such use.
2. Data used in AI development, testing, or training shall be anonymized or pseudonymized unless the use of identifiable data is explicitly authorized under contractual agreement or change management exclusions.
3. AI system data flows shall be mapped, documented, and reviewed at least annually.
4. Data subject rights (access, correction, deletion, objection to automated decision-making) shall be supported for AI processing subject to GDPR, CCPA/CPRA, and HIPAA.

5.4. AI Threat Management

MERGE shall implement AI-specific threat detection, prevention, and response capabilities.

1. AI threat modeling shall be conducted for all production AI systems addressing MITRE ATLAS and OWASP Top 10 for LLM threats.
2. AI systems shall undergo security testing prior to production deployment and at least annually thereafter, with additional testing triggered by significant model updates or security incidents.
3. AI-specific incident response procedures shall be maintained as part of MRG-011, covering detection, containment, model rollback, evidence preservation, and post-incident analysis.
4. AI systems exposed to external inputs shall implement input validation and sanitization controls proportionate to risk classification.

5.5. AI Model Security

MERGE shall implement controls ensuring the integrity, confidentiality, and availability of AI models throughout their lifecycle.

1. All changes to production AI models shall be documented, reviewed, and approved through change management prior to deployment.
2. AI models shall undergo pre-deployment testing validating functional correctness, security posture, and safety guardrail effectiveness.
3. Training data provenance, quality validation, and integrity checks shall be maintained for all AI models.
4. Output filtering and guardrails shall be implemented to prevent generation of harmful, biased, or policy-violating content.
5. Metaprompt security shall be implemented for LLM-based systems to prevent jailbreaking and unauthorized behavior manipulation.

5.6. AI Data Quality Management

MERGE shall ensure data used in AI systems meets quality, provenance, and integrity standards.

1. Training data shall have documented provenance including source, collection methodology, and quality assurance measures.
2. A data catalog for AI systems shall be maintained documenting available datasets, classification, and access controls.
3. Input and output quality monitoring shall be implemented for production AI systems to detect data drift, anomalous inputs, and model degradation.

5.7. AI Explainability and Accountability

MERGE shall implement transparency, accountability, and fairness controls for AI systems.

1. AI systems supporting decisions affecting individuals shall provide transparency proportionate to impact and regulatory requirements.
2. Bias identification and mitigation programs shall be established for AI systems with potential for discriminatory outcomes.
3. Each production AI system shall have a designated owner accountable for its security, performance, and compliance.
4. Human oversight requirements shall be defined based on AI system risk classification.

5.8. AI Access Controls

MERGE shall implement access controls protecting AI systems, models, data, and infrastructure from unauthorized access.

1. Access to AI systems shall follow the principle of least privilege, with documented business justification and quarterly review.
2. AI system APIs shall enforce strong authentication, authorization, and rate limiting to prevent abuse and model extraction.
3. Privileged access to AI model management functions must require multi-factor authentication.
4. AI system access events shall be logged, forwarded to Google SecOps SIEM, and retained per MERGE log retention requirements.

5.9. Cloud Provider and Third-Party AI Inheritance

MERGE shall leverage control inheritance from certified AI platform providers where appropriate.

1. AI platform providers shall be verified for HITRUST certification status and External Inheritance Program participation.
2. Shared responsibility matrices shall be obtained, reviewed, and documented for each AI platform provider.
3. Inheritance requests shall be submitted through HITRUST MyCSF for applicable controls, with complementary controls implemented for all gaps.

6. Compliance

Compliance with this policy is mandatory for all employees, contractors, and stakeholders. Noncompliance may lead to disciplinary actions, including termination of employment, and could lead to legal consequences if it involves violations of laws and regulations.

6.1. Exception Handling

This Policy may not apply in the following scenarios:

1. **Emergency Situations**: If this policy conflicts with an active security incident, follow the Incident Response Plan. Document the exception post-incident.

2. **Regulatory Conflict:** If this policy conflicts with a client-specific regulatory requirement, the Privacy Officer and Legal shall determine appropriate resolution with documented justification.
3. **Executive Overrides:** If an executive override is required, obtain documented approval from the CTO before deviating from this policy. The override, justification, and compensating controls shall be documented.

7. Enforcement

This policy will be enforced with regular audits and continuous monitoring conducted by the Information Security team. Any violations of the policy will be subject to thorough investigation, and appropriate disciplinary measures will be taken based on the severity of the noncompliance. Actions may include warnings, retraining, suspension of AI system access, suspension, or termination, depending on the nature of the violation.

8. Review & Change Management

This policy shall be reviewed regularly and updated as necessary to reflect changes in the AI threat landscape, regulatory requirements, HITRUST quarterly threat-adaptive updates, or organizational AI system changes.

Actions may include warnings, retraining, suspension, or termination, depending on the nature of the violation.

8.1. Review Frequency

- Quarterly Review: Minor updates for clarity, process improvements, and HITRUST threat-adaptive alignment.
- Annual Review: Full compliance and security review by TechOps leadership with documented approval.
- Ad Hoc Updates: Immediate updates for significant AI security incidents, regulatory changes, or material changes to AI systems.

8.2. Approval Workflow

All updates to this Policy must go through:

1. Review by Policy Owner
2. Compliance & Security Validation (Privacy/Legal)
3. Approval by TechOps Leadership

Once approved, the updated Policy is published and versioned in the Technical Documentation Repository.

9. Related Procedures

Procedures are maintained outside of policies. But for ease of use, we've linked the related procedures to this policy.

Related procedures:

PROC - AI Garage Operations

PROC - DevSecOps AI Integration

PROC - Google SecOps

Related policies:

Information Security Policy

Acceptable Use of Technology Policy

Incident Response

Data Policy

Privacy Policy

Third-Party Risk Policy

10. AI Code of Ethics

Preamble

In our unwavering commitment to merging "Storytelling + Technology," MERGE leadership has established this AI Code of Ethics. We aim to cultivate a forward-thinking mindset that embraces AI's experimental and purposeful use, while upholding ethical standards, security requirements, and regulatory compliance.

Principle 1 – Progressive Innovation

We shall adopt a progressive mindset, fostering a culture of experimentation with AI across agency practice areas, pushing the boundaries of creativity and innovation while maintaining security and privacy safeguards.

Principle 2 – Responsible Ideation

Agency members will use AI to facilitate creative brainstorming, concept development, copywriting, and programming when applicable. Proper attribution of generative AI assets shall be integrated into client-facing materials during concept reviews.

Principle 3 – Transparency and Client Approval

Without explicit disclosure and client consent, generative AI assets shall not be used as final output. Utilization for client deliverables shall be subject to client approval, supported within SOWs and additional agreements.

Principle 4 – Procedural Integrity

Integration of AI within specific platforms shall have well-defined purposes and processes, subject to an annual HITRUST review. MERGE's use of AI shall include selection of trusted and compliant AI platforms and rigorous vetting for copyright and intellectual property compliance.

Principle 5 – Ethical Integrity

No agency member shall knowingly employ generative AI to produce derivative works infringing upon existing copyright-protected creations or to generate content that is deceptive, discriminatory, or harmful.

Principle 6 – Security and Privacy by Design

AI systems developed, deployed, or procured by MERGE shall incorporate security and privacy considerations from the earliest stages of design, with threat mitigations, data protection controls, and compliance mechanisms integrated into architecture.

Revision History

Version	Date	Edited By	Approved by
1.0	Initial Draft	TOIT Leadership, IP Leadership, InfoSec Leadership	September 29, 2023
1.0	Review for 2024 IT acknowledgment	InfoSec	12/12/23

Revision History

Version	Date	Edited By	Approved by
	s, GRC platform language, and formatting update		
1.5	Made adjustments to address new services and systems at MERGE using AI	Jason Dittmer, Kyle Smith & Kurt Miller	10/27/25
2.0	Feb 18, 2026	Roze San Nicol…	TechOps/AI Garage Leadership
	Date	Person	Person
	Date	Person	Person

This document is controlled and maintained by MERGE TechOps. Unauthorized alterations are prohibited.